

Report: Audit of the Department of Defense Vulnerability Disclosure Policy (VDP)

1. Introduction

The U.S. Department of Defense (DoD) Vulnerability Disclosure Policy (VDP), hosted on the HackerOne platform, represents one of the most mature and influential federal frameworks for coordinated vulnerability disclosure. As cyber threats continue to evolve, the DoD relies on structured collaboration with the global security research community to identify weaknesses in publicly accessible DoD systems. This report provides a comprehensive audit of the DoD VDP, focusing on its safe harbor provisions, out-of-scope restrictions, verification standards, and broader governance implications. The analysis demonstrates competency in ethical hacking governance, legal compliance, and GRC-aligned security research practices, all of which are essential for professionals operating in modern cybersecurity environments.

2.1 Authorization for Good-Faith Security Research

The “Commitment” section of the DoD VDP functions as the backbone of its safe harbor protections. It explicitly authorizes good-faith security research on publicly accessible DoD information systems. This authorization is critical because it distinguishes legitimate vulnerability discovery from malicious intrusion. By affirming that research conducted within the policy’s boundaries is intended solely for defensive purposes, the DoD signals those ethical hackers are not adversaries but partners in strengthening national security.

2.2 Conditions Required to Maintain Safe Harbor

Safe harbor protections are not unconditional. The DoD outlines specific requirements that researchers must follow to remain protected. These include avoiding access to non-public or classified systems, refraining from exfiltrating sensitive data beyond what is minimally necessary to demonstrate impact, and ensuring that testing activities do not disrupt DoD services. Additionally, all findings must be submitted through the official HackerOne platform.

3. The “Kill Switch” – Out-of-Scope Activities

The Out-of-Scope section of the DoD VDP defines the boundaries that researchers must not cross. These restrictions function as a “kill switch,” meaning that violating them immediately voids safe harbor protections and may expose the researcher to legal consequences. The clarity of these boundaries is essential for maintaining operational security and preventing unintended harm.

3.1 Non-Public or Classified Systems

The first major category of prohibited activity involves any attempt to access non-public, internal, or classified DoD systems. This includes networks requiring VPN access, privileged credentials, or other forms of restricted authentication. Because these systems often contain sensitive or classified information, unauthorized access—even with good intentions—poses significant national security risks. As such, they are strictly off-limits.

3.2 Denial-of-Service or Service Disruption

The second category prohibits any form of denial-of-service (DoS) testing or activity that could degrade system performance. Flooding services with traffic, conducting stress tests, or performing resource exhaustion attacks are all explicitly banned. These activities can disrupt mission-critical DoD operations, making them incompatible with safe, controlled vulnerability research.

3.3 Social Engineering and Physical Intrusion

The third category forbids social engineering and physical intrusion attempts. Activities such as phishing, vishing, smishing, impersonation of DoD personnel, tailgating, or lock bypassing are not permitted under the VDP. These techniques target human or physical security rather than technical vulnerabilities and therefore fall outside the scope of authorized testing.

4.1 Valid Findings

A finding is considered valid when it affects an in-scope system, demonstrates real security impact, and includes clear, reproducible steps. Valid reports typically involve vulnerabilities such as cross-site scripting (XSS), SQL injection, insecure direct object references (IDOR), authentication bypasses, or misconfigurations with demonstrable consequences. Valid findings are routed for remediation and tracked internally until resolved.

4.2 Duplicate Findings

A duplicate finding occurs when the same underlying vulnerability has already been reported by another researcher. Even if the proof-of-concept differs, the root cause determines whether a report is considered a duplicate. Because VDPs operate on a “first-to-report” basis, duplicates do not receive separate credit, though they are acknowledged.

4.3 Informational Findings

Informational findings are reports that do not represent a meaningful security risk or lack demonstrable impact. Examples include missing security headers, benign version disclosures, or best-practice recommendations. While these findings may contribute to long-term hardening, they are not treated as actionable vulnerabilities.

5. Governance and GRC Implications

5.1 Alignment with Federal Cybersecurity Standards

The DoD VDP aligns with major federal cybersecurity frameworks, including CISA’s VDP maturity model, DOJ safe harbor guidance, and NIST recommendations for vulnerability handling. This alignment ensures consistency across federal agencies and reinforces best practices.

5.2 Importance for Ethical Hackers

For ethical hackers, understanding the VDP is essential for maintaining legal protection, demonstrating professional conduct, and avoiding criminal liability. Familiarity with scope boundaries and reporting requirements is a core competency in modern cybersecurity practice.

6. Conclusion

The DoD Vulnerability Disclosure Policy stands as a model for federal cybersecurity governance. Its safe harbor protections, clearly defined scope boundaries, and structured verification process create an environment where ethical researchers can contribute to national security without fear of legal repercussions. This audit highlights the importance of VDP literacy for both researchers and organizations, reinforcing the role of coordinated vulnerability disclosure as a cornerstone of modern cybersecurity strategy.